
Matriz de Riesgos

Actividad A03 — Administración de Riesgos
Análisis y Gestión de Riesgos en Sistemas de Información

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Contents

1	Datos Generales	2
2	Objetivo y Alcance del Análisis	2
3	Inventario y Clasificación de Activos	2
4	Identificación de Amenazas y Vulnerabilidades	3
5	Escalas de Valoración	4
5.1	Escala de Probabilidad	4
5.2	Escala de Impacto	4
6	Matriz de Calor (Probabilidad $\times$ Impacto)	5
6.1	Niveles de Riesgo	5
7	Evaluación de Riesgos	5
8	Tratamiento de Riesgos y Riesgo Residual	6
9	Resumen de Resultados	7
10	Conclusiones y Recomendaciones	7
11	Declaración de Buenas Prácticas	8
12	Referencias Bibliográficas	8

1. Datos Generales

Nombre de la empresa / organización / Clínica privada (caso desarrollado para TP SimpleRisk)

Rubro / Industria / Salud — atención médica privada

Tamaño (empleados / facturación) / 120 empleados, aprox. 800 pacientes atendidos por día

Alumno(s) / Grupo / Nicolás Estrella

Legajo(s) / 31.066.692

Fecha de elaboración / 10/09/2026

Responsable del análisis / Nicolás Estrella

2. Objetivo y Alcance del Análisis

Identificar, evaluar y proponer el tratamiento de los principales riesgos de seguridad de la información que afectan a una clínica privada, con foco en la confidencialidad, integridad y disponibilidad de las historias clínicas electrónicas (HCE) y los datos de pacientes, obras sociales y facturación.

Alcance: (sistemas, procesos, sedes o áreas incluidas en el análisis)

El análisis abarca el servidor de historias clínicas electrónicas, el proceso de facturación tercerizado con obras sociales, los accesos del personal administrativo y de enfermería al sistema de HCE, y la infraestructura eléctrica y de red del sitio principal de atención. No incluye otras sedes ni sistemas administrativos ajenos a la gestión clínica.

3. Inventario y Clasificación de Activos

Asigná un código único a cada activo (ej.: A01, A02...). La clasificación de la información puede ser: *Pública, Interna, Confidencial, Restringida*.

ID	Descripción del Activo	Tipo	Responsable	Clasificación	Criticidad
A01	Servidor de Historias Clínicas Electrónicas (HCE)	Software / Hardware	Nicolás Estrella	Restringida	Alta
A02	Base de datos de pacientes (datos de salud)	Información	Nicolás Estrella	Restringida	Alta
A03	Datos de obras sociales y facturación	Información	Nicolás Estrella	Confidencial	Alta
A04	Sistema de facturación tercerizado	Software	Proveedor externo	Confidencial	Media
A05	Credenciales de acceso del personal	Información	Nicolás Estrella	Restringida	Alta
A06	Infraestructura eléctrica (UPS / tablero)	Hardware	Nicolás Estrella	Interna	Media
A07	Red interna de la clínica	Red	Nicolás Estrella	Interna	Media
A08	Personal administrativo y de enfermería	Humano	Nicolás Estrella	—	Media
A09	Copias de seguridad (backups)	Información	Nicolás Estrella	Restringida	Alta
A10	Imagen institucional / reputación de la clínica	Imagen	Dirección	—	Media

Tipos de activo: Información / Software / Hardware / Red / Humano / Imagen. Criticidad: Baja / Media / Alta.

4. Identificación de Amenazas y Vulnerabilidades

Asigná un código único a cada amenaza (ej.: T01, T02...). El tipo puede ser: *Natural*, *Accidental*, *Intencional*.

ID	Activo (ID)	Descripción de la Amenaza	Tipo	Vulnerabilidad Asociada
T01	A01	Ataque de ransomware que cifra el servidor de HCE	Intencional	Sin EDR ni backups aislados
T02	A02	Acceso indebido de personal sin necesidad de conocer	Intencional	Falta de control de acceso basado en roles
T03	A09	Pérdida de datos por falla de hardware o error humano	Accidental	Backups inexistentes / nunca probados
T04	A03, A04	Filtración de datos por brecha en el proveedor externo	Intencional	Sin cláusulas contractuales de seguridad ni auditorías
T05	A01, A06	Corte de energía prolongado sin respaldo	Accidental	UPS insuficiente, sin generador
T06	A05, A08	Phishing dirigido a personal administrativo	Intencional	Falta de capacitación y de MFA
T07	A02, A03	Incumplimiento normativo (Ley 25.326)	Accidental	Sin procedimientos formales de resguardo de datos

5. Escalas de Valoración

5.1. Escala de Probabilidad

Valor	Nivel	Descripción
1	Raro	El evento solo ocurriría en circunstancias excepcionales.
2	Improbable	Podría ocurrir, pero no se espera que suceda.
3	Posible	Existe una posibilidad real de que ocurra.
4	Probable	Es muy probable que ocurra en algún momento.
5	Casi seguro	Se espera que ocurra frecuentemente / ha ocurrido recientemente.

5.2. Escala de Impacto

Valor	Nivel	Descripción
1	Insignificante	Impacto mínimo, sin consecuencias operativas ni económicas relevantes.
2	Menor	Alteración leve de la operación, costo bajo.
3	Moderado	Impacto operativo y económico apreciable, recuperable.
4	Mayor	Impacto significativo, pérdida de operación o datos, costo alto.
5	Catastrófico	Paralización total, pérdida crítica de datos, daño reputacional o legal severo.

6. Matriz de Calor (Probabilidad $\times$ Impacto)

La matriz 5×5 relaciona la **probabilidad** (eje vertical) con el **impacto** (eje horizontal). Cada celda muestra el valor de riesgo resultante ($P \times I$) y su color indica el nivel.

		IMPACTO $\rightarrow$				
		1	2	3	4	5
PROBABILIDAD $\uparrow$	5	5	10	15	20	25
	4	4	8	12	16	20
	3	3	6	9	12	15
	2	2	4	6	8	10
	1	1	2	3	4	5

6.1. Niveles de Riesgo

Nivel	Rango ($P \times I$)	Color	Acción requerida
Bajo	1 – 4	Verde	Monitorear. Puede aceptarse.
Medio	5 – 9	Amarillo	Plan de acción a mediano plazo.
Alto	10 – 15	Naranja	Tratamiento prioritario a corto plazo.
Crítico	16 – 25	Rojo	Acción inmediata. Escalar a dirección.

7. Evaluación de Riesgos

Asigná un código único a cada riesgo (ej.: R01, R02...). Calculá el valor como *Probabilidad* $\times$ *Impacto* y clasificá el nivel según la tabla anterior.

ID	Activo	Amenaza	Prob.	Impacto	Valor	Nivel	Justificación breve
R01	A01	T01	4	5	20	Crítico	Sector salud muy atacado por ransomware; sin EDR ni backups aislados.
R02	A02	T02	4	4	16	Crítico	Sin control de acceso por rol; visibilidad total de HCE.
R03	A09	T03	3	5	15	Alto	Sin política formal de backups ni pruebas de restauración.
R04	A05, A08	T06	4	4	16	Crítico	Sin capacitación ni MFA; puerta de entrada a otros ataques.
R05	A03, A04	T04	3	4	12	Alto	Proveedor externo sin cláusulas de protección de datos.
R06	A01, A06	T05	4	3	12	Alto	Cortes de energía frecuentes, sin respaldo suficiente.
R07	A02, A03	T07	3	4	12	Alto	Sin procedimientos documentados conforme a Ley 25.326.

8. Tratamiento de Riesgos y Riesgo Residual

Para cada riesgo, definí la estrategia de tratamiento:

- **Mitigar:** implementar salvaguardas para reducir probabilidad o impacto.
- **Transferir:** pasar el riesgo a un tercero (seguros, outsourcing).
- **Aceptar:** asumir el riesgo conscientemente.
- **Evitar:** discontinuar la actividad que lo genera.

Riesgo	Estrategia	Salvaguardas propuestas	Tipo salv.	Prob. resid.	Imp. resid.	Val. resid.	Nivel resid.
R01	Mitigar	Backups automatizados aislados/inmutables + EDR + segmentación de red	Técnica	2	4	8	Medio
R02	Mitigar	Control de acceso basado en roles (RBAC) + auditoría de accesos	Técnica	2	4	8	Medio
R03	Mitigar	Backups automatizados diarios con pruebas de restauración periódicas	Técnica	2	5	10	Alto
R04	Mitigar	Capacitación periódica + simulacros de phishing + MFA obligatorio	Administrativa	2	3	6	Medio
R05	Transferir	Cláusulas contractuales de protección de datos + auditorías al proveedor	Administrativa	2	3	6	Medio
R06	Mitigar	UPS de mayor capacidad + evaluación de generador de respaldo	Física	2	3	6	Medio
R07	Mitigar	Documentar procedimientos y designar responsable de tratamiento de datos	Administrativa	2	3	6	Medio

Tipo de salvaguarda: Técnica / Física / Administrativa. El nivel residual se clasifica con la misma tabla de la Sección 6.1.

9. Resumen de Resultados

Distribución de los riesgos identificados por nivel:

Nivel	Cantidad de riesgos	% del total
Crítico	3	43%
Alto	4	57%
Medio	0	0%
Bajo	0	0%
Total	7	100%

10. Conclusiones y Recomendaciones

El análisis identificó 7 riesgos relevantes, de los cuales 3 resultaron de nivel Crítico (ransomware sobre el servidor de HCE, acceso indebido a historias clínicas y phishing al personal administrativo) y 4 de nivel Alto. La causa común detrás de la mayoría de estos riesgos es la ausencia de controles técnicos básicos: backups aislados, control de

acceso por roles y autenticación multifactor. Se recomienda priorizar la implementación de backups inmutables y MFA como medidas de bajo costo y alto impacto, dado que reducen sensiblemente la probabilidad de los riesgos más críticos. Tras aplicar las salvaguardas propuestas, ningún riesgo residual queda por encima del nivel Alto, lo que valida la estrategia de tratamiento definida.

11. Declaración de Buenas Prácticas

Compromiso profesional

Como estudiante de Seguridad Aplicada a Sistemas de Información, declaro que el presente análisis de riesgos fue elaborado aplicando las buenas prácticas de la disciplina, con criterio ético, fundamentos técnicos y respetando el marco normativo vigente.

Firma del alumno/a

Fecha

12. Referencias Bibliográficas

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- ISO/IEC (2005). *Information security management 27001*.
- ISO/IEC (2018). *ISO/IEC 27005: Information security risk management*.
- NIST (2012). *Guide for Conducting Risk Assessments (SP 800-30 Rev. 1)*.
- OWASP Risk Rating Methodology: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology